

IntelliAudit: Using Large Language Models to Evaluate Audit Controls

Anonymous submission

Abstract

IT audits require auditors to determine whether heterogeneous organizational evidence satisfies security and compliance controls. This task is difficult to automate because controls are semantic, evidence is distributed across documents, spreadsheets, screenshots, and operational records, and audit judgment depends on evidentiary sufficiency rather than keyword matching. We present INTELLIAUDIT, a retrieval-grounded multi-agent system for IT audit evidence evaluation. Given a control and an evidence corpus, INTELLIAUDIT retrieves relevant artifacts, generates a primary assessment, challenges adverse findings, adjudicates disagreements, and produces an auditor-facing recommendation with cited evidence, rationale, missing-evidence analysis, and remediation guidance. We instantiate INTELLIAUDIT on ISO/IEC 27001:2022 and evaluate it on 14 controls across four simulated organizations using expert auditor review, cybersecurity-informed audit-readiness users, and a single-agent ablation. Auditors rated control understanding highly, with a mean score of 3.90/5 and 84% of ratings at 4 or above. Human feedback downgraded 15 of 27 reviewed assessments, showing the value of keeping auditors in the loop. These results suggest that retrieval-grounded multi-agent pipelines can support IT audit evidence review, but should not be treated as autonomous certification systems.

Introduction

IT audit engagements are evidence-heavy processes in which auditors assess an organization’s conformity to a standard such as ISO/IEC 27001:2022 (ISO/IEC 2022a). That standard requires an information security management system and a documented justification, the Statement of Applicability, for the Annex A reference controls the organization selects (ISO/IEC 2022b). The auditor’s task is therefore to test whether the selected controls are implemented and effective, not to match a control statement against a checklist. Auditing guidance frames this as collecting verifiable information and judging whether it is sufficient to support a conclusion (ISO 2018; ISO/IEC 2020). In practice, this requires more than reading the control text. Auditors must interpret the control objective, identify admissible evidence, inspect artifacts across multiple formats, determine whether

the evidence is sufficient, and explain gaps in a way that the audited organization can remediate. These tasks remain labor-intensive because evidence is distributed across policy documents, spreadsheets, screenshots, incident records, and other operational artifacts. The costs of these audits quickly becomes significant at scale. ISO/IEC 27001 is among the most widely held ISO certifications, and the literature records a persistent gap between documented and internalized practice, which is precisely what substantive evidence review is meant to detect (Culot et al. 2021). Expert interviews on ISO 27001 engagements (Brachten and Riasat 2024) and reviews of AI in audit practice (Leocádio, Malheiro, and Reis 2024) both motivate automating the manual portions of this work.

Large language models (LLMs) are a plausible fit for this setting. Prior work applies them to requirement interpretation and compliance judgment in regulated domains, including automated checking of data processing agreements against GDPR (Amaral et al. 2023), regulatory question answering grounded in structured knowledge (Agarwal et al. 2025), and policy-to-context alignment for compliance decisions (Chung et al. 2025). None of these settings turns on the evidentiary sufficiency judgment that ISO 27001 control assessment demands, so the transfer is a hypothesis this paper tests rather than an established result. Audit evidence evaluation is a high accountability task. Unsupported claims, hallucinated evidence, or premature compliance judgments can mislead both auditors and organizations. A useful system must therefore ground its reasoning in retrieved artifacts, expose the evidence behind each conclusion, handle partial and missing evidence, and allow human auditors to challenge the output.

Research Questions

We study the following question: *Can retrieval-grounded LLM agents assist the evidence-evaluation phase of IT auditing in a way that is explainable, robust to heterogeneous artifacts, and useful to auditors?* We operationalize this question through four research questions: (RQ1) whether LLMs can reason about audit controls beyond surface text; (RQ2) whether they can evaluate the factual sufficiency of supporting evidence; (RQ3) whether this reasoning extends across processed text, PDF, and spreadsheet artifacts; and (RQ4) whether the resulting explanations help non-auditors prepare for an audit.

This is an anonymized submission for review purposes only. Distribution, citation, or public sharing of this manuscript is strictly prohibited. Copyright and publication details will appear in the final version if accepted.

This paper makes three contributions. First, we formulate IT audit evidence evaluation as an explainable, evidence-grounded recommendation task rather than an autonomous certification task. Second, we introduce INTELLIAUDIT, a multi-agent workflow that combines retrieval, primary assessment, adversarial review, adjudication, and human feedback. Third, we construct an ISO 27001 benchmark with simulated but audit-realistic organizational evidence and evaluate the method through expert review feedback.

Related Work

LLMs for compliance and audit. LLMs have been used for compliance question answering, audit planning, and regulatory assessment. RAGulating Compliance combines multi-agent retrieval with structured regulatory knowledge (Agarwal et al. 2025), while Smart Audit studies LLM-supported supply-chain auditing in industry (Yao et al. 2024). Prior work also examines ISO 27001 audit automation (Brachten and Riasat 2024), LLM readiness in cybersecurity governance (McIntosh et al. 2024), password-policy auditing (Chin et al. 2025), and policy-context graph alignment for compliance judgments (Chung et al. 2025). Earlier NLP approaches check agreements against GDPR requirements (Amaral et al. 2023). In contrast, INTELLIAUDIT focuses on evidence evaluation for semantic ISO 27001 controls, where sufficiency must be assessed across heterogeneous evidence bundles rather than through policy matching or single checkable rules.

Retrieval-augmented compliance systems. RAG grounds model outputs in external evidence and mitigates unsupported generation (Lewis et al. 2021; Gao et al. 2024). Recent extensions include agentic RAG for multi-step retrieval and reasoning (Singh et al. 2026) and multimodal RAG over mixed inputs (Abootorabi et al. 2025). In regulated domains, RAG has supported risk-and-quality queries (Hillebrand et al. 2024) and FDA-guidance assessment of drug information and clinical-trial protocols (Waikar, Bhat, and Ramanathan 2026). INTELLIAUDIT extends this grounding principle from single-response compliance assistance to adversarial, multi-agent control assessment with evidence-linked explanations.

LLMs for financial audit. Financial-audit benchmarks reveal that LLMs struggle with taxonomy-aware reasoning, cross-document consistency, standards citation, and end-to-end audit execution (Wang et al. 2026b, 2025). AuditFlow addresses part of this challenge through a multi-agent workflow grounded in US-GAAP and XBRL graphs, while delegating numerical consistency checks to deterministic tools (Wang et al. 2026a). INTELLIAUDIT similarly uses evidence-grounded multi-agent reasoning, but targets semantic IT-audit controls whose sufficiency judgments cannot be reduced to deterministic checks; it further incorporates adversarial review, adjudication, and auditor feedback.

Human-in-the-loop LLM auditing. Human-AI collaboration can reveal failures missed by either humans or automated methods alone (Rastogi et al. 2023). LLMAuditor combines LLM-generated probes with human verification to

improve reliable model auditing (Amirizani et al. 2024), and broader work examines how feedback can be integrated into human-agent systems (Zou et al. 2026). Accordingly, INTELLIAUDIT treats auditors as active reviewers: feedback is routed through the Judge to revise traceable recommendations rather than manually overwrite them.

Multi-agent reasoning and document understanding. Multi-agent debate can improve reasoning by eliciting and adjudicating competing interpretations (Du et al. 2023); surveys further highlight the value of role specialization and structured coordination (Tran et al. 2025; Guo et al. 2024). D3 operationalizes this pattern through advocate, judge, and jury roles (Harrasse, Bandi, and Bandi 2026). INTELLIAUDIT adapts it to audit evidence with a Defender that challenges adverse findings and a Judge that resolves disagreements. Finally, our benchmark requires reasoning over enterprise documents and structured records, connecting to layout-aware document understanding, including LayoutLM-style models (Huang et al. 2022; Xu et al. 2022, 2020) and DocLLM (Wang et al. 2024).

Methodology

We formulate IT audit evidence evaluation as an explainable recommendation task and instantiate it with a retrieval-grounded multi-agent workflow. The formulation defines what must be produced for each control; the workflow describes how INTELLIAUDIT retrieves evidence, evaluates sufficiency, challenges adverse findings, and incorporates human feedback.

Task Formulation

Let $R = \{r_1, \dots, r_n\}$ denote the requirements in an audit framework and let $\mathcal{E}$ denote the engagement-specific evidence corpus. Requirements may depend on one another. We represent prerequisite relationships as a directed graph $G = (R, \mathcal{P})$, where $(r_i, r_j) \in \mathcal{P}$ means that requirement r_i must be satisfied before r_j can be meaningfully evaluated. Equivalently, G can be encoded by a dependency matrix $D \in \{0, 1\}^{n \times n}$, where $D_{ij} = 1$ iff $(r_i, r_j) \in \mathcal{P}$. Under audit state $S \subseteq R$, a requirement r_j is evaluable iff

$$\forall r_i \in R : (r_i, r_j) \in \mathcal{P} \Rightarrow r_i \in S.$$

Non-evaluable requirements are surfaced as prerequisite gaps rather than assigned a substantive compliance status.

Each requirement is associated with admissible evidence through a mapping

$$\alpha : R \rightarrow 2^{\mathcal{A}},$$

where $\mathcal{A}$ is the universe of audit artifacts, including policies, procedures, logs, spreadsheets, screenshots, diagrams, and video records. For a target requirement r_j , $\alpha(r_j)$ defines the evidence profile that the system should seek and cite.

Given an evaluable requirement r_j , corpus $\mathcal{E}$, and audit state S , INTELLIAUDIT approximates the audit-assistance function

$$F(r_j, \mathcal{E}, S) \rightarrow (\hat{y}_j, \mathcal{B}_j, \pi_j),$$

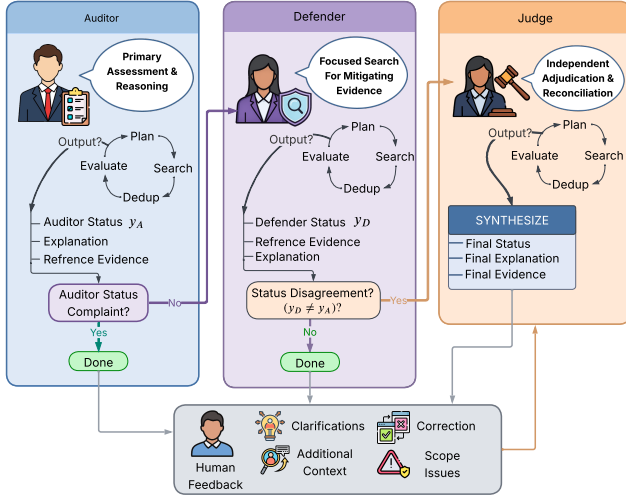


Figure 1: INTELLIAUDIT workflow. The Auditor performs the initial evidence-grounded assessment. The Defender searches for overlooked mitigating evidence when the finding is adverse. The Judge adjudicates disagreements and incorporates human feedback.

where

$$\hat{y}_j \in \{\text{COMPLIANT}, \text{PARTIAL}, \text{NON_COMPLIANT}, \text{INSUFFICIENT_EVIDENCE}\}$$

Here, $\hat{y}_j$ is an auditor-facing recommendation, $\mathcal{B}_j \subseteq \mathcal{E}$ is the cited evidence bundle, and π_j is an explanation that maps evidence to criteria, identifies gaps or conflicts, and recommends follow-up actions. **PARTIAL** indicates that the evidence supports some requirements while leaving others unmet or unsupported, whereas **NON_COMPLIANT** indicates a substantively unsupported or failed control. **INSUFFICIENT_EVIDENCE** is a Judge-issued review signal indicating that the available evidence is too incomplete, conflicting, or inconclusive to support a reliable compliance determination and that additional evidence or human auditor attention is required. In the current prototype, this abstention is therefore restricted to cases that reach the Judge through agent disagreement or human feedback. The goal is not autonomous certification, but an inspectable recommendation package for human auditor review.

Retrieval-Grounded Control Assessment

For each target requirement, INTELLIAUDIT first translates the evidence profile $\alpha(r_j)$ into a requirement-specific search space:

$$\mathcal{E}_j = \{e \in \mathcal{E} : e \text{ may support at least one criterion in } \alpha(r_j)\}.$$

The system then performs iterative retrieval over $\mathcal{E}_j$. Each iteration plans an evidence need, issues a targeted query, retrieves candidate artifacts, removes duplicates, and evaluates whether the current bundle is sufficient for assessment. Synthesis is performed only over the retrieved and cited bundle.

This prevents the system from assigning a status based solely on the control text or unsupported model priors.

The assessment output must satisfy three traceability constraints. First, every substantive claim in π_j should be supported by at least one cited artifact in $\mathcal{B}_j$. Second, missing or ambiguous evidence must be reported explicitly rather than treated as implicit compliance. Third, the recommended status $\hat{y}_j$ must follow from the explanation: a label is valid only if the cited evidence and rationale justify it.

Multi-Agent Review

INTELLIAUDIT decomposes control assessment into three role-specialized stages: Auditor, Defender, and Judge. This design targets two audit risks: unsupported compliance claims and missed mitigating evidence.

Auditor. The Auditor performs the primary assessment. Given r_j and $\mathcal{E}$, it retrieves evidence and returns

$$(\hat{y}_A, \mathcal{B}_A, \pi_A).$$

The Auditor is a position-taking agent and must select a provisional substantive status

$$\mathcal{Y}^{\text{sub}} = \{\text{COMPLIANT}, \text{PARTIAL}, \text{NON_COMPLIANT}\},$$

$$\hat{y}_A \in \mathcal{Y}^{\text{sub}}.$$

It identifies satisfied criteria, missing evidence, and unresolved uncertainty in π_A . When evidence affirmatively supports only part of the control, the Auditor assigns **PARTIAL**; it cannot assign the adjudicative abstention **INSUFFICIENT_EVIDENCE**.

Defender. The Defender is invoked only for adverse Auditor findings:

$$\hat{y}_A \in \mathcal{Y}^-, \quad \mathcal{Y}^- = \{\text{PARTIAL}, \text{NON_COMPLIANT}\}.$$

Its role is to check whether the Auditor overlooked compensating, mitigating, or differently located evidence. Given $(r_j, \mathcal{B}_A, \pi_A, \hat{y}_A)$, the Defender conducts a focused retrieval pass over underexplored parts of the evidence profile and returns

$$(\hat{y}_D, \mathcal{B}_D, \pi_D).$$

Like the Auditor, the Defender must propose a status in $\mathcal{Y}^{\text{sub}}$ and cannot assign **INSUFFICIENT_EVIDENCE**. Thus, the Defender does not advocate for compliance unconditionally; it stress-tests adverse findings before they are finalized.

Judge. The Judge is invoked when the Auditor and Defender disagree. It receives the combined evidence bundle

$$\mathcal{B}_{AD} = \text{DEDUP}(\mathcal{B}_A \cup \mathcal{B}_D)$$

and the two competing rationales. The Judge evaluates which interpretation is better supported by the combined evidence and produces

$$(\hat{y}_J, \mathcal{B}_J, \pi_J).$$

The Judge is the only agent permitted to return any status in the full set, including **INSUFFICIENT_EVIDENCE**. It selects a substantive status when the combined evidence

supports one; otherwise, it may abstain when neither position can be justified reliably. Reserving this abstention for the Judge prevents the Auditor from terminating the assessment prematurely and allows the Defender to search for overlooked evidence before the record is declared indeterminate. It also distinguishes `PARTIAL`, a substantive judgment that the evidence supports some criteria but not others, from `INSUFFICIENT_EVIDENCE`, an epistemic judgment that the record cannot sustain any substantive status. Because the Judge has access to both positions and their deduplicated evidence bundle, it is the stage best placed to make this higher-order sufficiency judgment. When the Auditor and Defender agree, their evidence and explanations are merged without adjudication, preserving the workflow’s selective escalation design.

Human Feedback

After the initial recommendation is produced, a human auditor may provide feedback h_j . Feedback can identify missing evidence, challenge a status label, correct a scope assumption, or add audit-specific context. `INTELLIAUDIT` routes h_j to the Judge rather than applying it as a manual overwrite. The Judge re-evaluates the previous recommendation, cited evidence, and feedback, and emits a revised tuple

$$(\hat{y}_H, \mathcal{B}_H, \pi_H)$$

when the feedback reveals a substantive evidentiary gap or misinterpretation. This preserves the evidence trail while allowing professional judgment to correct the system.

Control Assessment Procedure

Algorithm 1 summarizes the control-level procedure. The Auditor is always executed. The Defender is executed only for adverse findings where missed evidence could materially affect the outcome. The Judge is executed only when the Auditor and Defender disagree, or when human feedback is supplied. This design is cost-aware and auditable: additional reasoning is reserved for cases where it can change the recommendation.

The final output of every execution is a tuple $(\hat{y}_j, \mathcal{B}_j, \pi_j)$. A recommendation is considered valid only when the cited evidence bundle supports the explanation and the explanation justifies the assigned status. This requirement is central to `INTELLIAUDIT`’s design: audit labels are useful only when they remain inspectable, contestable, and grounded in evidence.

System Implementation

The prototype instantiates each control as a structured record containing its identifier, objective, evidence requirements, testing procedures, and compliance criteria. Organizational artifacts are normalized into source-traceable chunks [chunk size, overlap, and per-format handling for PDF, XLSX. Meeting with Sina and Diar together so we can identify the proper root cause of the ingestion/chunking failure that lead to the XLSX not being parsed in it’s entirety. We currently only discuss our hypothesis and how we mitigated it not the root cause.] and embedded with OpenAI `text-embedding-3-small` (OpenAI 2024). Chunks

Algorithm 1 INTELLIAUDIT Control Assessment

Require: Evaluable requirement r_j ; evidence corpus $\mathcal{E}$

Ensure: Recommendation $\hat{y}_j$, evidence bundle $\mathcal{B}_j$, explanation π_j

```

1:  $(\hat{y}_A, \mathcal{B}_A, \pi_A) \leftarrow \text{AUDITOR}(r_j, \mathcal{E})$ 
2: if  $\hat{y}_A \notin \mathcal{Y}^-$  then
3:    $(\hat{y}, \mathcal{B}, \pi) \leftarrow (\hat{y}_A, \mathcal{B}_A, \pi_A)$ 
4: else
5:    $(\hat{y}_D, \mathcal{B}_D, \pi_D) \leftarrow \text{DEFENDER}(r_j, \mathcal{E}, \mathcal{B}_A, \pi_A)$ 
6:    $\mathcal{B}_{AD} \leftarrow \text{DEDUP}(\mathcal{B}_A \cup \mathcal{B}_D)$ 
7:   if  $\hat{y}_D = \hat{y}_A$  then
8:      $(\hat{y}, \mathcal{B}, \pi) \leftarrow (\hat{y}_A, \mathcal{B}_{AD}, \text{COMBINE}(\pi_A, \pi_D))$ 
9:   else
10:     $(\hat{y}, \mathcal{B}, \pi) \leftarrow \text{JUDGE}(r_j, \mathcal{B}_{AD}, \pi_A, \pi_D)$ 
11:   end if
12: end if
13: if human feedback  $h_j$  is supplied then
14:    $(\hat{y}, \mathcal{B}, \pi) \leftarrow \text{JUDGE}(r_j, \mathcal{B}, \pi, h_j)$ 
15: end if
16: return  $(\hat{y}, \mathcal{B}, \pi)$ 
```

are stored in a persistent ChromaDB collection configured for cosine distance. Retrieval is dense rather than lexical, following the dual-encoder paradigm established for open-domain retrieval (Karpukhin et al. 2020; Reimers and Gurevych 2019). The Auditor, Defender, and Judge share a single retrieval configuration, top $k = 15$ with a similarity threshold of 0.35, held fixed across every reported run so that the ablation isolates the effect of the agent stages rather than of retrieval. Retrieved chunks retain source paths, chunk identifiers, scores, and query provenance so that generated findings can be traced back to inspectable artifacts.

The Auditor, Defender, and Judge are implemented as explicit state-machine workflows that track query plans, retrieved evidence, reasoning traces, continuation flags, and termination rationales. Planner and synthesis calls return structured fields and enumerated status values rather than unconstrained free text, providing stable interfaces between retrieval and reasoning. Human feedback from the survey interface is stored separately from generated recommendations and, when available, attached to the relevant control assessment before being passed back to the Judge for re-adjudication. Figure ?? summarizes how the offline indexing pipeline and the shared online adaptive-search workflow connect these implementation components.

Benchmark and Evaluation

We evaluate `INTELLIAUDIT` on the evidence-evaluation stage of an ISO 27001 audit. The goal is not to certify an organization automatically, but to test whether a retrieval-grounded multi-agent system can produce auditor-facing recommendations that are evidence-supported, useful, and robust across heterogeneous audit artifacts.

Benchmark Construction

Evidence corpus. Because real audit evidence is sensitive and rarely public, we construct a three-tier corpus. *Real-*

Control	Control objective	Artifacts
5.1	Policies for information security	DOC
5.2	Security roles and responsibilities (Org Chart)	PDF
5.9	Inventory of information and associated assets	XLSX
5.11	Return of assets	XLSX
5.24	Security incident management planning and preparation	DOC
5.25	Assessment and decision on security events	DOC
5.26	Response to security incidents	DOC
5.27	Learning from security incidents	DOC
5.29	Security during disruption	DOC
5.30	ICT readiness for business continuity	DOC
6.4	Disciplinary process	TXT
7.14	Secure disposal or reuse of equipment certification	PDF
8.1	User endpoint devices	XLSX
8.4	Access to source code	XLSX

Table 1: ISO 27001 controls used in the INTELLIAUDIT benchmark; the analysis covers DOC, TXT, PDF, and XLSX evidence.

RQ	Source	Evaluation signal
RQ1	Audit experts	Whether the explanation demonstrates control understanding beyond surface keyword matching.
RQ2	Audit experts	Whether cited evidence is factually relevant and sufficient for the assigned status.
RQ3	Audit and Compliance Users	Whether reasoning remains source-grounded across processed text, PDF, and spreadsheet evidence.
RQ4	Compliance users	Whether the output helps non-auditors identify and remediate audit-readiness gaps.

Table 2: Mapping from research questions to evaluation evidence.

world artifacts provide authoritative seed material, including public standards and guidance documents. *Expert-crafted artifacts* simulate operational evidence that organizations commonly produce but rarely disclose, such as organizational charts and asset inventories. *Synthetic artifacts* provide policy and procedural documents generated from the real-world and expert-crafted seeds. The full artifact inventory, generation prompts, and seed dependencies are reported on our website /tbUpdate website link after Panteha ports the site to the correct GitHub repo.

Evaluation Questions. The evaluation is organized around the four research questions introduced in Section . Table 2 maps each question to the corresponding evaluation signal.

Compliance Classification Schema

A control case was seeded as Compliant when the organization’s submitted artifacts fully satisfied the semantic requirements of the control language. Semi-Compliant cases partially addressed the control’s requirements, reflecting the common audit scenario where an organization demonstrates good-faith effort but has not fully implemented or evidenced a given control. Such a finding typically triggers a request

for additional population evidence or a compensating control. Non-Compliant cases did not address the control’s requirements in any meaningful way. This three-tier seeding schema is distinct from the system’s four recommendation statuses. A Semi-Compliant case is typically expected to elicit PARTIAL, while INSUFFICIENT_EVIDENCE marks cases where the retrieved bundle does not support a substantive judgment in either direction. We seed three tiers because binary pass/fail scoring does not reflect the graded judgments certified auditors make.

Experimental Setup

For each control, the system retrieves evidence from the artifact corpus and generates a structured recommendation package containing a status label, cited evidence, rationale, missing-evidence analysis, and recommended follow-up actions. All reported analyses are restricted to cases with processed text, PDF, and spreadsheet evidence.

Ablation Design

The ablation compares the single agent auditor only output against the final full-pipeline output for all 47 system executed cases (one case did not execute and is excluded), holding the corpus, retrieval configuration, and model backbone fixed, and then asks whether human reviewers prefer the pipeline’s intervention in the cases where it engaged. Across the matrix, the Judge activated in 5 of 47 cases (10.6%). It changed the Auditor only status in three (one PARTIAL to INSUFFICIENT EVIDENCE and two PARTIAL to NON-COMPLIANT) cases and preserved it in two. None of the changes was more permissive, and 44 of 47 final statuses (93.6%) matched the Auditor-only label. Adjudication is therefore an escalation path that engages rarely and tightens the finding when it does, rather than a wholesale rewrite. On the five activation cases, three eligible external reviewers each completed a blinded forced choice between the Auditor-only and Judge-final outputs, with A/B placement randomized per reviewer and balanced across the two slots (A 8, B 7). Because the five cases were purposively selected for Judge activation, choices are repeated within reviewer, recruitment was by convenience, one reviewer completed the comparison immediately after the twelve-case auditor survey, and no independent correctness label was collected, these results characterize reviewer preference on contested cases; we make no claim of universal multi-agent superiority.

Human Study Protocol

Because there is no public ground-truth dataset for ISO 27001 evidence sufficiency, we use human evaluation as the primary reference. Participants are divided into two groups. *Group A* consists of practicing auditors who evaluate whether the model’s reasoning and evidence use are professionally acceptable. *Group B* consists of cybersecurity students and compliance-oriented participants with cybersecurity backgrounds. We refer to them as *audit-readiness users*: non-auditors who use INTELLIAUDIT’s recommendations to identify evidence gaps, understand deficiencies, and prepare an organization for an audit.

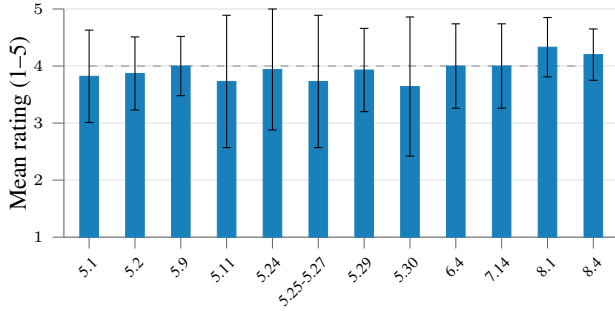


Figure 2: Auditor ratings of control understanding (RQ1) by ISO 27001 control. Bars show mean agreement that the recommendation reflects more than a surface reading of the control; error bars indicate ± 1 SD. Per-control n ranges from 5 to 17.

Each participant is assigned one of four simulated organizational profiles and reviews controls sequentially, beginning with Control 5.1. The survey uses 5-point Likert-scale questions with free-text justification fields for neutral or negative responses. Group A compares full multi-agent outputs against single-agent ablation outputs. Group B evaluates usefulness, actionability, and clarity of remediation guidance. The expected completion time is approximately 90 minutes for Group A and 45 minutes for Group B. Due to the prerequisite nature between 5.25, 5.26, and 5.27 (5.25->5.26->5.27) and one artifact (post incident analysis) providing the evidence for all three, we consolidated them into one survey question and had Group 1 evaluate them as a set, presented as 5.27.

Our human study was completed by 9 practicing auditors (Group A) and 25 cybersecurity master’s students and compliance professionals (Group B). We report results with respect to the four research questions; Table 2 maps each question to its evaluation signal.

Metrics

We report three classes of metrics.

Expert-rated reasoning quality. For RQ1 and RQ2, auditors rate control understanding, factuality of evidence use, sufficiency of the conclusion, and clarity of the explanation. We report mean Likert scores, standard deviations, and the percentage of outputs rated at least 4 out of 5.

Artifact coverage. For RQ3 we do not collect a separate rating. Instead, we group the RQ1, RQ2, and RQ4 responses by the primary artifact modality and compare rating distributions for cases that produced substantive outputs. This supports a descriptive comparison of unstructured text, PDFs, and spreadsheets.

Practical usefulness. For RQ4, Group B rates whether the output identifies concrete gaps, explains what evidence is missing, and provides actionable remediation guidance. We summarize Likert scores and representative qualitative comments.

Results

We report results with respect to the four research questions in our introduction. Overall, INTELLIAUDIT produced auditor-facing recommendations that were generally understandable when evidence-grounded. While useful for organization audit preparation, it lacked the reasoning capability to fully automate audit analysis: performance was descriptively stable across processed text, PDF, and spreadsheet evidence, but large spreadsheets exposed completeness errors. We therefore view INTELLIAUDIT as a HitL evidence-review assistant for human auditors and an audit preparation tool for organizations, rather than an autonomous compliance certification system.

Control Understanding (RQ1). Auditors rated whether each recommendation demonstrated understanding of the control beyond a surface reading. The pooled mean was 3.90 out of 5 (SD = 0.85), with 84% of ratings at 4 or above (Figure 2). This indicates that auditors usually found the explanations aligned with the semantic intent of the evaluated controls.

Disagreements reveal a useful failure pattern. When auditors criticized control interpretation, the system more often *overstated* evidence requirements than missed them. In structured deficiency responses, “gaps are overstated” was selected four times as often as “gaps are understated” (8 versus 2 of 24 responses). For example, on Control 5.1, the system treated the absence of a training-completion record as an acknowledgment gap, even though other acknowledgment mechanisms may satisfy the control. On Control 5.2, it treated a RACI matrix as effectively required, whereas the control requires that responsibilities be defined and allocated, not that a specific matrix format be used. These errors suggest that INTELLIAUDIT can articulate the control objective, but may sometimes translate flexible audit criteria into overly specific evidence expectations.

RQ1 therefore answers only part of the audit problem. The system can explain what a control is asking for, but a correct explanation does not guarantee a correct compliance status. We evaluate that harder sufficiency judgment under RQ2.

Evidence-Grounded Assessment (RQ2). Figure 3 separates two auditor judgments: whether INTELLIAUDIT’s evaluation of the evidence was factual and accurate, and whether the submitted evidence itself fulfilled the control. The factual-evaluation score was higher than the evidence-fulfillment score: 3.73 versus 3.15. This gap is expected because the benchmark compliant, semi-compliant, and non-compliant; low fulfillment ratings often reflect deliberately incomplete evidence rather than system failure. For example, Control 5.11 had a low fulfillment score of 2.80 but a higher factual-evaluation score of 3.88, indicating that auditors agreed the system recognized the weakness of the evidence.

The strongest factual ratings occurred when evidence bundles were small and self-contained. Control 7.14, based on disposal-certification evidence, and Control 8.1, based on machine-readable access-list exports, received among the highest factual ratings. The weakest cases exposed two distinct failure modes. First, *evidence completeness failures*: for Control 5.9, the system incorrectly inferred that the asset

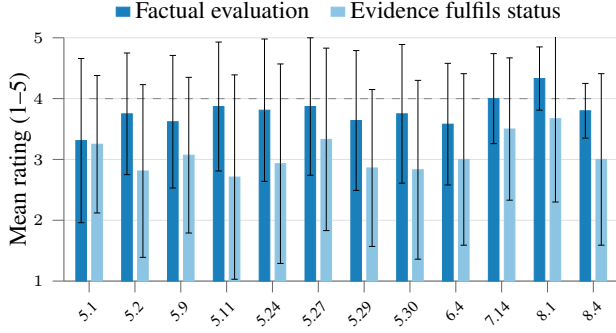


Figure 3: Auditor ratings of evidence evaluation (RQ2) by ISO 27001 control. Bars show mean ratings for factual evaluation of the evidence and whether the available evidence fulfils the control; error bars indicate ± 1 SD. Per-control n ranges from 5 to 16.

inventory contained only hardware-prefixed assets, although the spreadsheet also included software, mobile, and peripheral entries. A rerun with a newer (Sonnet 5) backbone ingested the full inventory and did not reproduce this hardware-only reading, but serialization failures prevented treating that rerun as a clean end-to-end result. Control 5.29 exposed a different retrieval issue: the system failed to surface a relevant post-incident report because it had been indexed under the consolidated 5.25–5.27 evidence path. Second, *status-calibration failures*: for Controls 5.24 and 6.4, the system identified substantive gaps but still assigned COMPLIANT in many cases. Auditors rejected these lenient labels, and the feedback stage later corrected several of them.

These findings separate three subproblems that are often conflated in LLM evaluation: retrieving the right evidence, interpreting that evidence factually, and mapping identified gaps to an audit status. INTELLIAUDIT performs reasonably on factual interpretation, but the results show that stronger completeness checks and stricter label calibration are needed before such systems can be trusted beyond assisted review.

Reasoning Across Artifact Types (RQ3). Among cases with substantive outputs, we grouped ratings by primary evidence type (Figure 4). Auditor ratings were similar for unstructured text, PDFs, and spreadsheets: 3.75 (SD = 1.03, $n = 186$), 3.90 (SD = 0.76, $n = 59$), and 3.89 (SD = 0.88, $n = 90$), respectively. Audit-readiness-user ratings followed a similar but slightly lower pattern for spreadsheets: 3.80 (SD = 1.01, $n = 144$) for text, 3.84 (SD = 0.96, $n = 50$) for PDFs, and 3.49 (SD = 1.24, $n = 51$) for spreadsheets.

These results suggest that reasoning quality does not collapse when moving from narrative documents to processed PDF and spreadsheet evidence. However, they should not be interpreted as a causal modality comparison because controls and organizations were not randomized across artifact types. The spreadsheet cases illustrate the limitation: aggregate ratings were stable, but Control 5.9 still failed because population-level completeness reasoning over a large inventory was harder than reasoning over a small document. This is an audit-specific requirement that ordinary retrieval met-

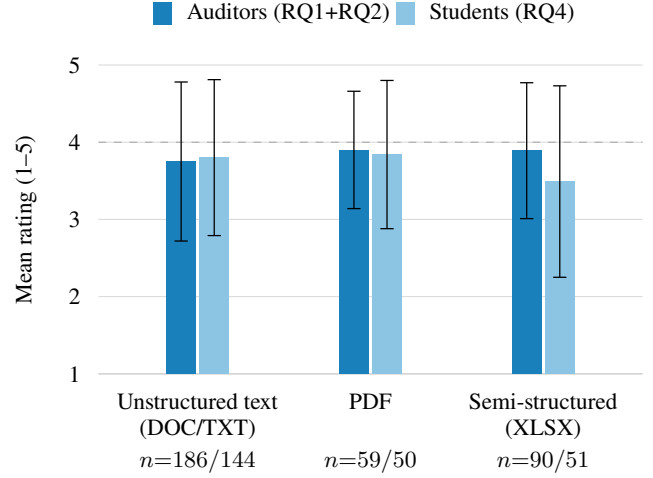


Figure 4: Ratings by primary evidence type (RQ3). Auditor ratings combine control understanding and factual evidence evaluation; audit-preparation-user ratings measure usefulness. Error bars indicate ± 1 SD.

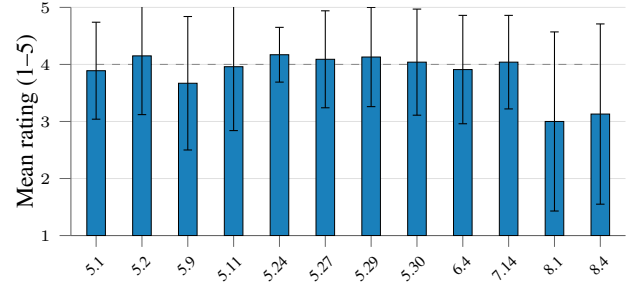


Figure 5: Audit-preparation usefulness ratings (RQ4) by ISO 27001 control. Bars show mean agreement that the recommendation supports remediation or communication of deficiencies; error bars indicate ± 1 SD. Controls 8.1 and 8.4 are excluded from the pooled mean.

rics can miss: a system may retrieve relevant rows while still failing to verify coverage over the full population.

Audit-Preparation Usefulness (RQ4). Audit-readiness users rated whether INTELLIAUDIT helped them identify deficiencies and determine what to do next. Across the ten controls with substantive recommendations, the mean usefulness rating was 4.00 out of 5 (SD = 0.92, $N = 241$), indicating that users generally found the output actionable (Figure 5). Ratings were strongest when the recommendation connected a concrete evidence gap to a clear remediation step, such as producing missing policy evidence, clarifying roles, or supplying additional records.

Controls 8.1 and 8.4 are excluded from the pooled usefulness score because a survey error meant the audit-preparation cohort did not receive comparable recommendations for these controls. Their lower, higher-variance ratings (3.00 and 3.13, SD approximately 1.6) reflect the affected presentation rather than recommendation quality. Users did not rate the af-

fects outputs positively, which supports the internal validity of the remaining responses.

Effect of Multi-Agent Review. The multi-agent stages were designed as an escalation mechanism, not as a routine rewrite of every assessment. Across the four orgs the Judge activated in 5 cases (10.6%). It changed the Auditor-only status in three cases and preserved it in two. All three status changes were stricter, including one PARTIAL to INSUFFICIENT EVIDENCE and two PARTIAL to NON-COMPLIANT. None made the result more permissive. Thus, 44 of 47 final statuses (93.6%) matched the Auditor-only label, showing that adjudication was selective and conservative.

We separately evaluated the five Judge-activation cases (Controls 5.30, 5.1, 5.11, and 5.9 twice, spanning four organizations) with a blind forced-choice comparison. Three external reviewers each compared the Auditor-only and Judge-final outputs, yielding 15 judgments. Reviewers preferred the Judge output in 9 of 15 choices and the Auditor only output in 6. The preference was concentrated on the three status-changing cases, where 7 of 9 choices favored the Judge. On the two status preserving cases, the Auditor output was preferred 4 out of 6 times.

Human feedback as audit calibration. Auditors used the interactive feedback channel on 27 surveyed assessments, sending 43 follow-up messages. Each message was routed to the Judge as an adjudication signal rather than applied as a manual overwrite. 15 of the 27 assessments changed status after feedback, and all 15 changes were downgrades, most often from an initial COMPLIANT label.

This result is important because the highest-cost audit failure is optimistic certification in the presence of missing evidence. The feedback channel acted as a conservative correction mechanism: auditors challenged lenient conclusions, and the Judge accepted those corrections without revising any status upward. For example, when an auditor asked why Control 5.30 had been rated compliant despite the absence of continuity-testing evidence, the Judge revised the status to INSUFFICIENT EVIDENCE. Control 6.4 followed the same pattern: the system recognized that enforcement records existed but the underlying disciplinary policy was missing, and all three feedback-driven re-adjudications moved the status downward.

Failure Modes and Per-Control Patterns. The control-level analysis reveals four recurring failure modes. First, INTELLIAUDIT sometimes over-required specific evidence formats that were not mandated by the control. This occurred in Controls 5.1 and 5.2, where the system treated training records or a RACI matrix as necessary evidence rather than as one possible way to demonstrate acknowledgment or responsibility allocation. Second, the system struggled with population-level completeness reasoning over large spreadsheets. Control 5.9 was the clearest example: the system generalized from an initial subset of inventory rows and incorrectly claimed that the inventory contained only hardware assets. A rerun with an updated backbone (Sonnet 5) ingested the full inventory, but did not constitute a clean end-to-end evaluation.

Third, INTELLIAUDIT sometimes identified the right gaps but assigned overly lenient labels. This pattern appeared in Controls 5.24–5.27 and 6.4, where the pipeline noted missing or incomplete evidence but still produced COMPLIANT assessments in several cases. Human feedback was particularly useful for this failure mode, as all three re-adjudications for Control 6.4 moved the status downward. Fourth, retrieval was sometimes scoped too narrowly to connect related evidence across controls. In Control 5.29, the system failed to surface a relevant post-incident report because that report had been indexed under the consolidated 5.25–5.27 evidence path.

Stronger outcomes occurred when the evidence was small, directly relevant, and easy to align with the control objective. Control 7.14 was the strongest case: the system made an appropriately conservative PARTIAL assessment from disposal certification evidence, while auditors noted that a single certificate did not establish population level coverage. Controls 8.1 and 8.4 also produced reasonable findings on machine-readable XLSX access-list exports, correctly identifying that account or repository exports alone do not establish endpoint protection or managed source-code access. Overall, these patterns motivate audit-specific improvements: explicit sufficiency calibration, population-level spreadsheet checks, and cross-control evidence linking.

References

- Abootorabi, M. M.; Zobeiri, A.; Dehghani, M.; Mohammadkhani, M.; Mohammadi, B.; Ghahroodi, O.; Baghshah, M. S.; and Asgari, E. 2025. Ask in Any Modality: A Comprehensive Survey on Multimodal Retrieval-Augmented Generation. arXiv:2502.08826.
- Agarwal, B.; Jomraj, H. S.; Kaplunov, S.; Krolick, J.; and Rojkova, V. 2025. RAGulating Compliance: A Multi-Agent Knowledge Graph for Regulatory QA. arXiv:2508.09893.
- Amaral, O.; Azeem, M. I.; Abualhaija, S.; and Briand, L. C. 2023. NLP-Based Automated Compliance Checking of Data Processing Agreements Against GDPR. *IEEE Transactions on Software Engineering*, 49(9): 4282–4303.
- Amirizani, M.; Yao, J.; Laverne, A.; Okada, E. S.; Chadha, A.; Roosta, T.; and Shah, C. 2024. LLMAuditor: A Framework for Auditing Large Language Models Using Human-in-the-Loop. arXiv:2402.09346.
- Brachten, C. E. W.; and Riasat, S. I. 2024. Automating ISO 27001 Consultancy and Auditing using AI: A Feasibility Study Based on Expert Interviews. Preprint, Utrecht University, supervised by R. L. Jansen.
- Chin, J. H.; Zhang, P.; Cheong, Y. X.; and Pan, J. 2025. Automating Security Audit Using Large Language Model based Agent: An Exploration Experiment. arXiv:2505.10732.
- Chung, J.; Ko, R.; Yoo, W.; Onizuka, M.; Kim, S.; Kim, T.-W.; and Shin, W.-Y. 2025. GraphCompliance: Aligning Policy and Context Graphs for LLM-Based Regulatory Compliance. arXiv:2510.26309.
- Culot, G.; Nassimbeni, G.; Podrecca, M.; and Sartor, M. 2021. The ISO/IEC 27001 information security management standard: literature review and theory-based research agenda. *The TQM Journal*, 33(7): 76–105.
- Du, Y.; Li, S.; Torralba, A.; Tenenbaum, J. B.; and Mordatch, I. 2023. Improving Factuality and Reasoning in Language Models through Multiagent Debate. arXiv:2305.14325.
- Gao, Y.; Xiong, Y.; Gao, X.; Jia, K.; Pan, J.; Bi, Y.; Dai, Y.; Sun, J.; Wang, M.; and Wang, H. 2024. Retrieval-Augmented Generation for Large Language Models: A Survey. arXiv:2312.10997.
- Guo, T.; Chen, X.; Wang, Y.; Chang, R.; Pei, S.; Chawla, N. V.; Wiest, O.; and Zhang, X. 2024. Large Language Model based Multi-Agents: A Survey of Progress and Challenges. arXiv:2402.01680.
- Harrasse, A.; Bandi, C.; and Bandi, H. 2026. Debate, Deliberate, Decide (D3): A Cost-Aware Adversarial Framework for Reliable and Interpretable LLM Evaluation. In *Proceedings of the 19th Conference of the European Chapter of the Association for Computational Linguistics (Volume 1: Long Papers)*, 8376–8392. Rabat, Morocco: Association for Computational Linguistics.
- Hillebrand, L.; Berger, A.; Uedelhoven, D.; Berghaus, D.; Warning, U.; Dilmaghani, T.; Kliem, B.; Schmid, T.; Loitz, R.; and Sifa, R. 2024. Advancing Risk and Quality Assurance: A RAG Chatbot for Improved Regulatory Compliance. In *2024 IEEE International Conference on Big Data (Big-Data)*, 8668–8670.
- Huang, Y.; Lv, T.; Cui, L.; Lu, Y.; and Wei, F. 2022. LayoutLMv3: Pre-training for Document AI with Unified Text and Image Masking. arXiv:2204.08387.
- ISO. 2018. ISO 19011:2018, Guidelines for Auditing Management Systems. International Organization for Standardization, Geneva, Switzerland. Third edition.
- ISO/IEC. 2020. ISO/IEC 27007:2020, Information Security, Cybersecurity and Privacy Protection — Guidelines for Information Security Management Systems Auditing. International Organization for Standardization, Geneva, Switzerland. Third edition.
- ISO/IEC. 2022a. ISO/IEC 27001:2022, Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements. International Organization for Standardization, Geneva, Switzerland. Third edition.
- ISO/IEC. 2022b. ISO/IEC 27002:2022, Information Security, Cybersecurity and Privacy Protection — Information Security Controls. International Organization for Standardization, Geneva, Switzerland. Third edition.
- Karpukhin, V.; Oğuz, B.; Min, S.; Lewis, P.; Wu, L.; Edunov, S.; Chen, D.; and tau Yih, W. 2020. Dense Passage Retrieval for Open-Domain Question Answering. arXiv:2004.04906.
- Leocádio, D.; Malheiro, L.; and Reis, J. 2024. Artificial Intelligence in Auditing: A Conceptual Framework for Auditing Practices. *Administrative Sciences*, 14(10): 238.
- Lewis, P.; Perez, E.; Piktus, A.; Petroni, F.; Karpukhin, V.; Goyal, N.; Küttler, H.; Lewis, M.; tau Yih, W.; Rocktäschel, T.; Riedel, S.; and Kiela, D. 2021. Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks. arXiv:2005.11401.
- McIntosh, T. R.; Susnjak, T.; Liu, T.; Watters, P.; Nowrozy, R.; and Halgamuge, M. N. 2024. From COBIT to ISO 42001: Evaluating Cybersecurity Frameworks for Opportunities, Risks, and Regulatory Compliance in Commercializing Large Language Models. arXiv:2402.15770.
- OpenAI. 2024. New Embedding Models and API Updates. <https://openai.com/index/new-embedding-models-and-api-updates/>.
- Rastogi, C.; Ribeiro, M. T.; King, N.; Nori, H.; and Amershi, S. 2023. Supporting Human-AI Collaboration in Auditing LLMs with LLMs. arXiv:2304.09991.
- Reimers, N.; and Gurevych, I. 2019. Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks. arXiv:1908.10084.
- Singh, A.; Ehtesham, A.; Kumar, S.; Khoei, T. T.; and Vasiliakos, A. V. 2026. Agentic Retrieval-Augmented Generation: A Survey on Agentic RAG. arXiv:2501.09136.
- Tran, K.-T.; Dao, D.; Nguyen, M.-D.; Pham, Q.-V.; O’Sullivan, B.; and Nguyen, H. D. 2025. Multi-Agent Collaboration Mechanisms: A Survey of LLMs. arXiv:2501.06322.
- Waikar, S.; Bhat, A. G.; and Ramanathan, M. 2026. Retrieval Augmented Generation (RAG) for Evaluating Regulatory Compliance of Drug Information and Clinical Trial Protocols. *CPT: Pharmacometrics & Systems Pharmacology*, 15(3): e70201.

Wang, D.; Raman, N.; Sibue, M.; Ma, Z.; Babkin, P.; Kaur, S.; Pei, Y.; Nourbakhsh, A.; and Liu, X. 2024. DocLLM: A Layout-Aware Generative Language Model for Multimodal Document Understanding. In *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, 8529–8548. Bangkok, Thailand: Association for Computational Linguistics.

Wang, R.; Liu, J.; Zhao, W.; Li, S.; and Zhang, D. 2025. Automating Financial Statement Audits with Large Language Models. arXiv:2506.17282.

Wang, Y.; Ai, X.; Patel, J.; Peng, X.; Mo, F.; Cao, Y.; Li, H.; Cao, M.; Qian, L.; and Gutiérrez-Basulto, V. 2026a. AuditFlow: Executable Symbolic Environments for Structured Financial Reporting Verification. arXiv:2606.03031.

Wang, Y.; Wang, K.; Yang, S.; Patel, J.; Zhao, J.; Mo, F.; Peng, X.; Qian, L.; Chen, Y.; Gutiérrez-Basulto, V.; Huang, J.; Xiong, G.; Liu, X.-Y.; Liu, X.; and Nie, J.-Y. 2026b. FinAuditing: A Financial Taxonomy-Structured Multi-Document Benchmark for Evaluating LLMs. Accepted to SIGIR 2026 (Resource Track), arXiv:2510.08886.

Xu, Y.; Li, M.; Cui, L.; Huang, S.; Wei, F.; and Zhou, M. 2020. LayoutLM: Pre-training of Text and Layout for Document Image Understanding. In *Proceedings of the 26th ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, KDD ’20, 1192–1200. ACM.

Xu, Y.; Xu, Y.; Lv, T.; Cui, L.; Wei, F.; Wang, G.; Lu, Y.; Florencio, D.; Zhang, C.; Che, W.; Zhang, M.; and Zhou, L. 2022. LayoutLMv2: Multi-modal Pre-training for Visually-Rich Document Understanding. arXiv:2012.14740.

Yao, X.; Wu, X.; Li, X.; Xu, H.; Li, C.; Huang, P.; Li, S.; Ma, X.; and Shan, J. 2024. Smart Audit System Empowered by LLM. arXiv:2410.07677.

Zou, H. P.; Huang, W.-C.; Wu, Y.; Guo, J.; Chen, Y.; Miao, C.; Nguyen, H.; Zhou, Y.; Zhang, W.; Fang, L.; Zhang, H.; Wang, F.; Zhang, P.; Wang, H.; He, L.; Li, Y.; Li, D.; Jiang, R.; Liu, X.; and Yu, P. S. 2026. LLM-Based Human-Agent Collaboration and Interaction Systems: A Survey. arXiv:2505.00753.